

Augmented Offense — Module 1:

FI3\$hH00k (NTAG216 NDEF)

Len Noe & Dr. Gregory Carpenter · CW PENSEC

Phone · NFC Tools

Module 1 — FI3\$hH00k: a URL that launches on tap, with zero interaction

Implant analog: xNT. **Tool:** your phone + NFC Tools. **FI3\$hH00k** is the tap that becomes a phish.

Objective attendees reach

Write a URL NDEF record to an NTAG216 and watch an iPhone surface it **with no app open and no button pressed**. The victim did nothing.

Materials

- Attendee phone (iPhone or Android) with **NFC Tools** installed
 - 1× NTAG216 per attendee
 - Optional Tier-1: pod laptop running `module1/hook_server.py` on a network you control
-

Step by step (both platforms)

1. Open **NFC Tools** → **Write** → **Add a record** → **URL/URI**.
2. In the URL field, enter `https://adversaryvillage.org/` (the default for this lab — a benign, real destination). *(Advanced/Tier-1 only: instead use the local URL that `hook_server.py` prints, to demo the laptop callback.)*
3. Tap **Write**, then hold the NTAG216 to the phone.

4. **Re-tap to read it back** and confirm the record is a **URL** type.
5. Now tap it to an **iPhone with no app open** — iOS surfaces the link as a notification on its own. *That passivity is the whole point.*

Tier 0 (everyone, zero install)

Open `module1/index.html` (hosted page or written to the tag). The page shows what it already knows about the visitor — user-agent, platform, screen, timezone — without asking. Point: you opened nothing, yet a page is profiling you.

Tier 1 (optional, live callback — on your own laptop)

1. Read `module1/beacon.js` and `module1/hook_server.py` first.
2. `cd module1 && python3 hook_server.py` → it prints a URL.
3. Write that URL to the NTAG216; uncomment the single Tier-1 line in `index.html`.
4. Tap with your phone → your phone appears in the laptop log. That's the callback.

Why it matters

An implant (like an xNT) behaves identically to this card at the reader — the operator's hand *is* the tag. A handshake becomes a phish; the operator doesn't need a device, they *are* the device.

Defensive angle

Treat tap-to-URL as untrusted input; apply MDM policy to background NDEF. The tap is the delivery, the trusted-looking prompt is the exploit — social-engineering amplified by hardware.

Failure modes

Symptom	Cause	Fix
iPhone won't auto-open the link	record not written as URL type	rewrite as a URL record
Reads are flaky	13.56 MHz floor congestion	move off-pod, use the Faraday pouch to isolate, re-tap
Tier-1 phone can't reach laptop	not on the same controlled network	put both on the pod hotspot

Safety

The default URL is the **real, benign Adversary Village site** (<https://adversaryvillage.org/>) — the point is the *passive launch*, not the destination. No credential harvesting. The optional Tier-1 beacon talks only to your own laptop. No attendee phone is ever a target of another attendee.

Presenters

- **Len Noe (213)** — <https://www.linkedin.com/in/len-noe/>
- **Dr. Gregory Carpenter (JunkBond)** — <https://www.linkedin.com/in/gcarpenter-cw-pensec/>